



5/8/2026

BASIC DETAILS

Name	Kenya Institute of Primate Research (KIPRE)
Category	Government Institution
Email Address	ceo@primateresearch.org
Name	+254202606235
Establishment Document	Uploaded
Postal Address	P.O Box 24481-00502
Country	Kenya
County	KAJIADO

REGISTRATION REPRESENTATIVE

Name	Patrick Waweru Mwaura
Email Address	mwaure76.pm@primateresearch.org
Phone Number	+254741527254
Relation / Role	Staff Member, Head Data science and analytics section

PERSONAL DATA

Employees and Dependents.

Current and former employee records including payroll details, banking channels, tax data, performance management files, medical insurance schemes, leave balances, pension records, and internal disciplinary files.

Human resource administration, contractual execution, and mandatory statutory tax or health compliance tracking.

Job Applicants.

Curriculum Vitae (CVs), academic certificates, transcripts, professional references, national identification numbers, background check verifications, and interview evaluation records.

Talent acquisition, credential verification, recruitment management, and selection workflows.

Students, Interns, and Casuals.

Institutional attachment letters, university enrollment verifications, technical research project logs, and student performance tracking metrics.

Execution of statutory capacity building, institutional training tracking, and academic partnership management.

Suppliers, Vendors, and Consultants.

Individual consultant profiles, corporate contact directories, commercial contracts, KRA PIN certificates, bank accounts, and payment history logs.

Procurement workflows, supplier vetting, and institutional contract management.

Research Participants (Human Subjects).

Demographic information, signed informed consent forms, clinical histories, survey questionnaires, laboratory sample tracking metadata, and health-status diagnostics (KIPRE Policy Articles 2.3 and 3.5).

Conduct of ethical basic, pre-clinical, and translational health research.

Website and Online Service Users.

Network tracking cookies, IP addresses, online identifier logs, and submission data via the KIPRE eCitizen Platform or official web portal (KIPRE Policy Article 6.1).

Digital service delivery, platform cybersecurity monitoring, and public inquiry tracking.

Board Members.

State appointment gazette notices, governance profiles, tax compliance certificates, and board remuneration or sitting allowance accounts.

Institutional governance, ministerial compliance, and corporate accountability.

Facility Visitors and Nature Trail Customers.

Physical entry logbooks, national identification checks, digital ticketing transaction trails, and 24/7 CCTV surveillance footage (KIPRE Policy Article 6.3).

Institutional campus security, perimeter asset protection, access control, and public nature trail safety management.

SENSITIVE DATA

Racial or ethnic origin

Collection and profiling for demographic characterization, epidemiological analysis, population-based biomedical research, and statistical reporting in approved institutional research studies (KIPRE Policy Article 2.3 & 3.5).

Property Details (Including Financials)

Collection and retention for employee administration, payroll processing, procurement vendor onboarding, research grants management, reimbursement workflows, and statutory financial compliance audits (KIPRE Policy Article 3.4 & 10).

Religious, philosophical conscience and beliefs

Collection where explicitly relevant and volunteered for employee welfare programs, localized religious dietary/holiday accommodations, or specific approved study protocol requirements (KIPRE Policy Article 4.2 & Annex III).

Marital (Include spouse and childrens details)

Collection for human resource management, medical insurance scheme administration, pension scheme structures, employee benefits processing, emergency contact records, and statutory labor law compliance (KIPRE Policy Article 2.4.2).

Health Status (Physical or Mental Health)

Collection for biomedical research programs, occupational health tracking, medical monitoring, clinical assessments, laboratory investigations, and institutional employee/student welfare support systems (KIPRE Policy Article 1.5 & 3.2).

Sex/Sexual Orientation

Collection for demographic analysis, biomedical and public health research, epidemiological studies, and standardized scientific reporting under approved research protocols (KIPRE Policy Article 2.3).

Biometric data

Collection and technical mapping for research participant identification, laboratory sample linkage, high-security infrastructure access control, automated attendance management, and research system authentication procedures (KIPRE Policy Article 6.3).

GPS Location Data

Collection for field research coordination, epidemiological mapping, geospatial analysis, biological sample collection transit tracking, and operational field logistics (KIPRE Policy Article 3.3.ii).

Genetic data

Collection and genomic sequencing for biomedical, molecular, genomic, and translational research involving laboratory analysis and advanced scientific investigations (KIPRE Policy Article 2.3.vi & 3.5.iii).

TRANSFER OF DATA OUTSIDE KENYA

PREVIOUS YEAR TURNOVER AND NUMBER EMPLOYEES

RISK AND SAFEGUARD MEASURES

Technical Safeguards

1. Endpoint Detection, Response (EDR) and Antivirus Utilities

Function: Runs continuous automated behavioral monitoring, algorithmic threat neutralization, daily definition downloads, and weekly full-system endpoint sweeps, combined with inbound/outbound corporate email inspection and automated weekly sweeps of archived mail databases (Article 6.1). Systems or Data Protected: Protects administrative workstations, local endpoints, internal mail exchanges, laboratory information systems, and archived email directories containing employee records, job applications, and research communication history.

Contribution to Protection: It isolates and blocks malicious code vectors (Trojans, spyware, rootkits, fileless malware) before execution, preventing system hijack and silent tracking of data subjects.

2. Access Controls: Password Complexity Rules & Automated Session Timeouts

Function: Systematically enforces credential thresholds requiring an 8-to-14 character length, alphanumeric and special character complexity, a maximum 60-day password age limit, and a lockout lock after 4 failed login attempts. It forces local screensaver locks to activate within 5 minutes of terminal inactivity.

Systems or Data Protected: Protects user profiles, internal network directory infrastructure, and human resource databases containing employee payroll files, banking channels, tax data, and disciplinary records.

Contribution to Protection: It stops brute-force credential attacks. Forcing inactivity timeouts ensures unauthorized internal actors or campus visitors cannot view or alter open data records on unmonitored physical endpoints.

3. Secure Email protection Gateways & Domain Authentication (SPF, DKIM, DMARC)

Function: Deploys boundary email filtering systems that parse incoming communication packets against multi-layer spam identification algorithms, look up domain authentication records (SPF, DKIM, DMARC), and block staff access to untrusted web domains (Article 6.1.iii).

Systems or Data Protected: Protects corporate communication systems, official email interfaces, and employee identity registries against incoming external delivery vectors.

Contribution to Protection: Intercepts business email compromise (BEC) messages and phishing traps, lowering the risk of employees clicking fraudulent digital links that lead to personal credential harvesting.

4. Multi-Factor Authentication (MFA) and Centralized System Transaction Logging

Function: Enforces Multi-Factor Authentication (MFA) across all local and remote authentication channels, paired with system-wide generation of

immutable, unalterable system logs tracking every user profile creation, data alteration, financial modification, or administrative override action (Article 6.3).

Systems or Data Protected: Protects database perimeters, internal access points, data transfer layers, and financial directories containing procurement vendor information and research grant financial disbursements.

Contribution to Protection: Prevents network intrusion even if primary passwords are stolen. Unalterable audit trails provide complete forensic tracking, actively deterring unauthorized internal data manipulation.

5. Automated Data Backup Solutions & Network Segmentation

Function: Executes automated system-state, data repository, and registry backups every single night, coupled with network segmentation architecture designed to divide network infrastructure into distinct security zones.

Systems or Data Protected: Protects production databases, file repositories, and master clinical research nodes containing sensitive human clinical histories and laboratory data.

Contribution to Protection: Ensures continuous data availability, resilience, and immediate system restoration capacity during ransomware events or hardware failures. Network segmentation limits lateral threat movement, containing malware infections to isolated local zones.

6. Role-Based Access Control (RBAC) & Administrative Privilege Separation

Function: Enforces technical separation of privileges across the network, partitioning system access permissions into distinct categories: standard restricted users, power users, and system operators/administrators.

Systems or Data Protected: Protects underlying database layers, operating systems, and application-level configuration controls.

Contribution to Protection: Enforces the data minimization principle by restricting data access views strictly to personnel executing legitimate statutory duties, preventing standard users from viewing sensitive biomedical datasets.

7. Advanced Cryptographic Data Encryption (At Rest and In Transit)

Function: Applies high-grade cryptographic data encryption layers utilizing advanced key management frameworks for data stored within internal databases (at rest) and data traversing network communication channels (in transit), backed by continuous Intrusion Detection Systems (IDS) (Article 2.3.vi).

Systems or Data Protected: Protects the national non-human primate research indices, biomedical laboratory sequencing repositories, and translational health tracking records.

Contribution to Protection: Renders high-risk research and personal datasets completely unreadable to intercept utilities. If data files are digitally exfiltrated during a cyberespionage attempt, the information remains cryptographically secure and useless to the attacker.

8. Environment Isolation and Secure Gateway API Tokens

Function: Establishes complete network environment isolation and encrypted transaction pathways that separate core corporate financial databases from public revenue APIs, such as the eCitizen payment interface (Article 3.3.iv). Systems or Data Protected: Protects financial billing records, online ticket transaction histories, and public nature trail customer access logs.

Contribution to Protection: Prevents the interception of financial or card payment data. By isolating payment handling systems from core operations, it shields internal user directories from external payment gateway risks and transactional fraud.

9. Air-Gapped Controls and Disconnected Backup Media Storage

Function: Generates physically disconnected, encrypted, offline backup media snapshots that are fully isolated from the active network infrastructure.

Systems or Data Protected: Protects baseline production records, historical data volumes, long-term public health databases, and core application configuration files.

Contribution to Protection: Acts as an absolute defense against cyber extortion and blackmail. Because these backups are completely air-gapped from the network, ransomware attackers cannot access, delete, or encrypt them, ensuring KIPRE can restore its systems without paying extortion fees.

10. Firewalls, Load Balancers, and Intrusion Prevention Systems (IPS) Function: Deploys boundary perimeter hardware firewalls executing strict packet rate limiting, Intrusion Prevention Systems (IPS) designed to match malicious traffic signatures, and network load balancers to distribute traffic across server clusters.

Systems or Data Protected: Protects public-facing web portals, official submission systems, data routing switches, and network boundaries.

Contribution to Protection: Defends the institution against Distributed Denial of Service (DDoS) attempts. It preserves data availability and accessibility for authorized stakeholders, preventing malicious actors from overwhelming network resources to take systems offline.

11. Technical Data Loss Prevention (DLP) Parameters

Function: Implements centralized Data Loss Prevention (DLP) screening rules that actively monitor endpoint activities, flag massive data transmission spikes, and block file copy operations to unauthorized external storage devices or USB peripheral media.

Systems or Data Protected: Protects terminal USB ports, web data export interfaces, and storage drives containing sensitive personal data.

Contribution to Protection: Stops the unauthorized theft or sale of corporate registries by restricting internal staff or malicious individuals from exfiltrating large volumes of personal data to external flash drives or unvetted cloud storage repositories.

12. Web Application Firewalls (WAF) and Input Field Sanitization

Function: Deploys a dedicated Web Application Firewall (WAF) to inspect application-layer requests, implements strict input validation routines across all web forms, and tracks patch management updates for public web resources.

Systems or Data Protected: Protects public-facing portals, visitor booking platforms, and web host configurations.

Contribution to Protection: It neutralizes Advanced Persistent Threats (APTs) and application attacks, such as Remote File Inclusions, SQL Injections, and Cross-Site Scripting (XSS). This prevents attackers from hijacking web interfaces to manipulate or download underlying database tables.

13. Cloud Access Security Brokers (CASB) and Internally Managed Cloud Encryption

Function: Implements Cloud Access Security Brokers (CASB) to enforce identity boundaries, paired with cloud-side database encryption where the cryptographic keys are managed strictly within KIPRE's on-premise hardware infrastructure.

Systems or Data Protected: Protects off-site hosting platforms, distributed computing nodes, and cloud storage instances.

Contribution to Protection: Protects off-site data pools against cloud-specific account takeovers, misconfigured cloud storage leaks, and unauthorized vendor-side access, ensuring privacy-by-design standards extend beyond physical campus perimeters.

Organisational Safeguards

1. Institutional Governance, DPO Designation, and Policy Oversight

Administrative Scope: Establishes a dedicated internal data protection governance infrastructure under the direct coordination of the designated Data Protection Officer (DPO), mapped directly to the Deputy Director of the ICT Division (Article 3.2). Operational Execution: The DPO is administratively empowered to monitor institutional compliance, maintain the centralized annual data risk register (Article 9.6), and serve as the structural liaison with the Office of the Data Protection Commissioner (ODPC). The ICT Division maintains direct administrative authority over data availability, access authorizations, and structural system tracking configurations (Article 3.3).

2. Statutory Data Breach Triage and Incident Escalation Framework

Administrative Scope: Enforces rigid internal reporting timelines to manage system vulnerabilities, malware anomalies, or potential data compromises (Article 7). Operational Execution: KIPRE policy establishes a strict internal data incident workflow requiring all personnel to log discovered data disruptions or security anomalies with the DPO within 24 hours of discovery (Article 3.6.ii). Technical network infrastructure or core system disruptions must be escalated to the DPO within four (4) working hours of detection (Article 7.3). Following formal validation, the Data Controller executes its statutory mandate to notify impacted data subjects and the ODPC within 72 hours if a breach poses a real risk of harm (Article 7.2).

3. Independent Compliance Auditing and Risk Assurance

Administrative Scope: Implements continuous objective oversight loops to review data management streams, transaction histories, and security adequacy standards (Article 3.4 & Article 10).

Operational Execution: The Internal Audit and Risk Assurance Directorate is contractually and administratively tasked with conducting comprehensive data protection risk assessments biannually (Article 10). These audits independently verify system access privileges, check the integrity of transaction logs, and evaluate the operational adequacy of KIPRE's technical and

Physical Safeguards

to prevent data manipulation.

4. Mandatory Employee Awareness and Security Capacity Building

Administrative Scope: Formally integrates data privacy and information security training mandates into the institutional onboarding and continuous professional development paths for all KIPRE personnel (Article 2.1.13.v & Article 6.2). Operational Execution: Under the coordination of department supervisors and the ICT Division, employees must undergo mandatory training sessions addressing data classification standards, phishing red flags, secure credential handling, and social engineering indicators. This structural education builds an institutional culture of confidentiality and data minimization.

5. Binding Non-Disclosure Frameworks and Vendor Contract Vetting

Administrative Scope: Establishes legal boundaries and strict data handling obligations over all external entities, third-party contractors, suppliers, and research collaborators interfacing with KIPRE data repositories (Article 3.5).

Operational Execution: The Corporation Secretary and Legal Services Unit must review all procurement contracts, memorandum of understanding agreements, and research collaborations. These legal instruments are strictly required to embed explicit Data Processing Agreements (DPAs) and binding Non-Disclosure Agreements (NDAs) that hold external processors legally liable to KIPRE's privacy standards (Article 3.5.ii & Annex I).

6. Informed Consent Management and Data Subject Rights Fulfillment

Administrative Scope: Sets a standardized administrative framework to respect, process, and execute the statutory rights of data subjects regarding data access, corrections, or processing objections (Article 4.2).

Operational Execution: KIPRE administers rigorous informed consent workflows where signed data subject consent is securely verified, documented, and archived prior to any biomedical processing or external research data-sharing operations (Article 4.2 & Annex III). The DPO maintains dedicated channels to ingest and process Data Subject Access Requests (DSARs) within the legal timelines required by the Data Protection Act, 2019.

7. Post-Employment Confidentiality and Enforceable Disciplinary Measures

Administrative Scope: Codifies structural accountability, holding employees responsible for internal data manipulation, unauthorized sharing, or policy violations during and after their tenure (Article 1.7.2 & Article 9.5).

Operational Execution: All employment contracts embed binding confidentiality restrictions that remain legally enforceable against personnel for twelve (12) months following their formal separation from KIPRE (Article 1.7.2). Any internal attempt to bypass safeguards or leverage corporate technology infrastructure for unauthorized data alteration or personal financial gain triggers immediate HR disciplinary action up to summary dismissal, without precluding direct criminal prosecution under national laws (Article 3.6.ii & Article 9.5).

PHYSICAL SAFEGUARDS:

1. Biometric Security Restrictions and Datacenter Perimeter Isolation

Physical Scope: Structural isolation and physical perimeter boundary controls protecting core institutional server installations and primary telecommunication facilities.

Operational Execution: Central data centers, routing cabinets, and network switches are housed behind specialized security doors equipped with

electronic biometric fingerprint/iris entry parameters. Entry is structurally restricted to designated ICT Division network operators, and every physical entry event is automatically logged by an independent electronic security logging system to block unauthorized hardware access or physical utility sabotage (Article 6.3).

2. Spatial Restrictions Over Proprietary Research and Clinical Facilities

Physical Scope: Tiered badge-holder tracking zones and spatial access controls safeguarding highly sensitive medical and scientific data repositories across KIPRE campuses (Article 6.3). **Operational Execution:** Enhanced physical barriers and security access gates isolate areas housing national non-human primate research indices, preclinical laboratory spaces, and translational population health datasets. Unvetted personnel, casual workers, or general facility visitors are completely blocked from entering these zones without official security clearance and formal badge verification loops (Article 1.5.g & Article 6.3).

3. Administrative Workstation Orientation and Terminal Lock Security

Physical Scope: Local workstation physical desk arrangements and office environment boundary protections to counter local data visibility risks. **Operational Execution:** Workstation monitors within open-plan administrative offices are physically oriented to prevent visual shoulder-surfing vectors or data exposure to passersby. All personnel are required to mechanically lock their local terminal hardware whenever stepping away from their desks, ensuring that physical access endpoints are entirely protected from unauthorized viewing or physical tampering (Article 6.1 & Article 6.3).

4. Around-the-Clock CCTV Surveillance Coverage and Entry Monitoring

Physical Scope: 24/7 high-definition Closed-Circuit Television (CCTV) surveillance networks monitoring high-value administrative and revenue collection rooms.

Operational Execution: Continuous video monitoring is deployed across the procurement department, billing registries, accounting clusters, and institutional vault spaces (Article 6.3). CCTV terminal logs and backup footage recordings are securely stored and restricted to the security division to preserve the integrity of physical financial tracking trails.

5. Locked Fireproof Registry Storage and Document Bins

Physical Scope: Physical containment systems deployed for securing hard-copy data assets, transaction ledgers, next-of-kin files, and historical research books.

Operational Execution: All hard-copy files containing personal data or financial tracking profiles are locked within specialized, fire-resistant filing cabinets. Central administrative departments utilize secure, locked document disposal bins to collect legacy paper data waste, preventing data leaks or harvesting from office trash streams (Article 6.3 & Article 8).

6. Off-Site Fireproof Safe Storage for Critical Media Backups

Physical Scope: Hardened, isolated physical storage facilities utilized for long-term cryptographic backup disks and system restore points.

Operational Execution: To protect against localized physical emergencies or campus-wide disasters, duplicate copies of system backups and data repositories are physically transferred to off-site, geographically distributed safe storage zones (Article 8). These backups are sealed within climate-controlled, industrial-grade fireproof safes, completely air-gapped from any network connectivity to guarantee baseline restoration capability.

7. Institutional Visitor Management Systems and Badge Protocols

Physical Scope: Campus-wide reception screening workflows and visitor entry authorization processes deployed at all primary facility entry points.

Operational Execution: All external guests, trail visitors, and contractors must register their national identification details at the main security checkpoints before entering KIPRE administrative compounds. Guests are issued colored visitor badges and are strictly required to remain under staff escort at all times, completely blocking unescorted visitors from accessing restricted operational desks or laboratory clusters (Article 6.3).